



CVE-2025-20309: CISCO UNIFIED CM STATIC ROOT CREDENTIAL VULNERABILITY

Vairav CVE Report

Date: July 03, 2025

Vairav Cyber Threat Intelligence Team

Vairav Technology Security Pvt. Ltd.

Thirbam Sadak 148

Baluwatar, Kathmandu

Phone: +977 4541540

Mobile: +977-9820105900

Email: sales@vairavtech.com

EXECUTIVE SUMMARY

Cisco has released a critical security advisory addressing severe remote code execution vulnerability (CVE-2025-20309) in Cisco Unified Communications Manager (Unified CM) and Session Management Edition (SME). The flaw, rated CVSS 10.0, arises from static root SSH credentials left over from development, exposing systems to unauthenticated remote root access. No authentication is required, and attackers can gain complete system control.

VULNERABILITY DETAILS

CVE-2025-20309: Static Root SSH Credential in Cisco Unified CM/SME

Description: A vulnerability caused by including static, hardcoded root credentials in specific ES (Engineering Special) releases of Cisco Unified CM and SME, intended only for development. These credentials cannot be changed or removed.

Impact: Full remote compromise. An unauthenticated attacker could log in via SSH as root and execute arbitrary commands.

CVSS Score: 10.0 (Critical)

AFFECTED PRODUCTS/VERSIONS

- Cisco Unified CM ES releases: 15.0.1.13010-1 through 15.0.1.13017-1
- Cisco Unified CM SME ES releases: 15.0.1.13010-1 through 15.0.1.13017-1

EXPLOIT DETAILS

Exploitation requires no user interaction or authentication. An attacker can initiate an SSH session using the hardcoded credentials, gaining immediate root-level access. The presence of vulnerability can be detected by checking logs such as `/var/log/active/syslog/secure` for suspicious root-level SSH login attempts:

```
Apr 6 10:38:43 cucm1 authpriv 6 sshd: pam_unix(sshd:session): session opened for user root by (uid=0)
```

Cisco recommends retrieving logs using the following command:

```
file get activelog syslog/secure
```

RECOMMENDED ACTIONS

- **Patch Immediately:** Apply the July 2025 Service Update (15SU3) or the standalone patch provided by Cisco.
- **Upgrade Systems:** Move to a version not affected by static development credentials.
- **Monitor Logs:** Review system logs for unauthorized root logins via SSH.
- **Audit Access:** Reassess SSH and admin access policies for Unified CM and SME.

REFERENCES

<https://securityonline.info/cve-2025-20309-cvss-10-cisco-patches-critical-static-ssh-root-credential-flaw-in-unified-cm/>

<https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-cucm-ssh-m4UBdpE7>

<https://www.cve.org/CVERecord?id=CVE-2025-20309>

CONTACT US

Vairav Technology Security Pvt. Ltd.

Cyber Defender from the land of Gurkha

Thirbam Sadak 148, Baluwatar

Kathmandu, Nepal

Phone: +977-01-4541540

Mobile: +977-9820105900

Email: sales@vairavtech.com

Website: <https://vairavtech.com>